# TechniView ethics statement

**Document lead:** Jason Bellerjeau
**Component review:** Ryan Sippy, Jason Bellerjeau, and Derek Corniello
**Status:** Pilot planned for February 15 to March 14, 2027; UC IRB approval pending.

TechniView is a course-linked coding practice platform. Students submit Python code and see results; course staff assign problems and review progress. The D0-D2 design, Week 9 requirements, technical specification, and pilot consent form define the flows discussed here. The D1 diagram is a historical schema snapshot; the current ORM and D2 inventory cover later account, course, and submission additions.

## Privacy summary

Pilot participants review and sign the consent form before account creation. The form explains collection, team access, research sharing, and withdrawal. It does not imply that ordinary website use alone grants research consent. The survey is hosted separately in UC Qualtrics, configured without names, email addresses, or identifying link details, and is not joined to TechniView accounts. The pilot does **not** collect a UC M-Number: the internal account ID already links activity, and the extra identifier is unjustified.

In the table, **pilot consent** means that signed pre-account form. **Service use** means a specific action by an authorized participant or course staff member after consent. MySQL is on encrypted UC-hosted storage; hourly encrypted off-host backups follow the deployment schedule. The exact retention or deletion period for identifiable originals is subject to applicable UC IRB requirements and has not been set in this repository. Withdrawal ends access and new collection, but does not erase already collected data, as the signed form states.

| Data item crossing D0-D2 boundaries | Source and purpose | Consent | Storage and access | Retention / disposition |
|---|---|---|---|---|
| Name, email, account ID, role, verification and disabled status | Participant / staff; identity and access | Pilot consent; account signup | UC MySQL; participant and authorized trained pilot team | IRB-governed originals; de-identify eligible pilot data at pilot end |
| Password hash; session token hash and session times | Login; authenticate and revoke access | Pilot consent; login | UC MySQL; API service; raw session token only in HTTP-only browser cookie | Session expires after 7 days or is revoked; old DB rows have no documented purge job |
| Course names, descriptions, join-token hashes, roster roles, enrollment invitations and withdrawal dates | Staff / participants; course access and historical roster | Pilot consent; staff invitation or join action | UC MySQL; course staff and authorized team | IRB-governed originals; withdrawn memberships remain for history |
| Problem statements, tags, examples, test cases, canonical solutions, question sets and assignments | APPS/APPS+ import or staff authors; teaching and grading | Staff publication; dataset license | UC MySQL; published content to eligible users; hidden cases and solutions withheld from students | Catalog and assignment history retained until a governed deletion decision |
| First-open times, attempt counts, scores, errors, progress and course analytics | Student activity and grader; feedback and evaluation | Pilot consent; problem use | UC MySQL; student own results, authorized course staff and trained pilot team | IRB-governed originals; grouped summaries may remain after withdrawal |
| Submitted source code, run/submit IDs, timing, status and idempotency keys | Student browser; execute, grade and prevent duplicate requests | Pilot consent; explicit run or submit | UC MySQL; student, authorized course staff and trained team; code sent to private go-judge | Originals follow IRB requirements; idempotency keys expire after 24 hours and worker purges them |
| Test inputs/expected outputs, stdout, stderr, compiler output, exception type, CPU time and memory use | MySQL test cases / go-judge; grade and troubleshoot | Pilot consent; run or submit | UC MySQL results; private runner processes each case without its own submission DB | Originals follow IRB requirements; raw code/output excluded from shared research export |
| Email verification/reset tokens, pending enrollment, email jobs and delivery errors | Account action; verify, recover or invite | Pilot consent; requested account action | Token hashes/jobs in UC MySQL; Resend processes account email; local development writes owner-only mail files | Tokens expire and can be used once; no general DB purge schedule is documented |

| Data item crossing D0-D2 boundaries | Source and purpose | Consent | Storage and access | Retention / disposition |
|---|---|---|---|---|
| Source-address request counters | Signup, join and recovery requests; rate limiting | Pilot consent; account request | Hashed action/address key and count in UC MySQL; API service | One-hour window resets on later request; no row purge job documented |
| Request IDs, route/status/duration, worker events, aggregate metrics | API and workers; operations and troubleshooting | Pilot consent disclosure; service operation | Docker rotating local logs, latest three 10 MiB files per service; private Prometheus/Grafana for metrics | Rotation by size; no longer-term log collector configured in repo; labels omit identity, code and case IDs |
| Grade CSV and pseudonymous research CSV | Operator/staff export; grades or approved research | Pilot consent and authorized export | Grade CSV to authorized course staff; research file owner-only on UC host, excluding names, email, code, raw output and timestamps | Review before sharing; research codes unlink from identities at pilot end; de-identified set may be kept indefinitely if IRB permits |
| Database backups | UC MySQL; recovery | Pilot consent covers stored data | Encrypted off-host campus restic repository; authorized operators | Hourly for one day, daily for one month, weekly for three months, monthly for one year; originals remain subject to IRB rules |

At project end, the team will prepare the de-identified dataset under UC IRB requirements and remove the link between participant codes and identities before sharing. No automatic account, submission, or backup deletion mechanism for that event exists yet. The team must carry out the approved disposition and verify it across primary storage and backups before claiming deletion.

# Security summary

**Default credentials.** Local Compose deliberately seeds teacher@techniview.local / teacher-demo and student@techniview.local / student-demo. The production deployment does not seed demo users; an operator provisions the first instructor. Production MySQL and mail secrets are unique files under /etc/techniview/secrets with restricted permissions, mounted only into services that need them. This production distinction matters more than claiming the project has no default accounts anywhere.

**Unauthenticated endpoints.** Public reads and /api/health exist; account and course actions use scrypt password login, an HTTP-only SameSite=Lax session cookie, hashed server-side session tokens, role and course-membership checks, and logout revocation. Sessions default to seven days. Production Compose sets COOKIE_SECURE=true, Caddy serves HTTPS with HSTS, and account signup, join and recovery are limited to 30 requests per source address per hour in MySQL. This is not a general API-wide rate limit. The pilot is planned within the campus VPN; runner port 5050 is bound to a private interface and firewalled to the application host. The runner uses cgroup resource limits, seccomp, an isolated network namespace, an unprivileged student process, and a dedicated host; its container itself remains privileged.

**Secrets in source control.** .env is ignored. Production uses mounted secret files, and the research export needs a separately configured HMAC secret. I searched all 166 commits reachable from git log --all -p for added private-key headers, common cloud/GitHub token prefixes, and key/secret/password/token assignments. No private-key or provider-token prefix matched. The broad assignment search yielded 45 candidate lines in Compose examples, tests, seed data and benchmark files; this heuristic is not a gitleaks audit and does not prove the absence of every secret. No history rewrite or credential rotation was performed as part of this documentation update.

| Self-audit question | Answer and evidence |
|---|---|
| Can demo credentials reach production? | Production deployment imports the catalog but does not run the local demo seed. |
| Can a student use a staff endpoint? | Session and course-role checks guard staff routes; public problem and health reads remain intentionally open. |
| Are secrets in source control? | The 166-commit heuristic scan found no key/token prefix match; 45 broad candidates were in examples/tests/benchmarks. A dedicated secret scanner remains a stronger follow-up. |
| Are transport and runner boundaries defined? | Caddy HTTPS/HSTS, Secure cookie, campus VPN, private runner bind/firewall and sandbox controls are specified for production. |

| Self-audit question | Answer and evidence |
|---|---|
| Is deletion automatic at the pilot end? | No. IRB-governed disposition and backup verification remain operational work. |

# Licensing summary

The project code is MIT licensed. Versions below come from pyproject.toml, uv.lock, frontend/package-lock.json, and production image declarations; the table lists directly declared software and project inputs, not every transitive lockfile package. SPDX identifiers follow the SPDX license list. MIT and BSD-3-Clause require preservation of copyright/license notices; Apache-2.0 additionally requires its notices and change marking where applicable. Third-party services keep their own licenses and are not relicensed as MIT.

| Dependency, dataset or asset | Version | SPDX | Type | Obligation / decision |
|---|---|---|---|---|
| FastAPI; Alembic; PyMySQL; SQLAlchemy | 0.141.1; 1.16.5; 1.2.0; 2.0.52 | MIT | Permissive | Preserve notices |
| HTTPX; Uvicorn | 0.28.1; 0.52.4 | BSD-3-Clause | Permissive | Preserve notice and disclaimer |
| React; React DOM; React Router; Monaco React | 18.3.1; 18.3.1; 7.18.4; 4.7.0 | MIT | Permissive | Preserve notices |
| ESLint, plugins/configs, Testing Library, React type packages, Vite plugin, jsdom, Prettier, Vitest, globals, typescript-eslint | Locked versions in frontend/package-lock.json | MIT | Permissive, development | Preserve notices; individual versions listed in README attribution |
| TypeScript | 6.0.3 | Apache-2.0 | Permissive, development | Preserve license and notices; mark changes if redistributed |
| Python development tools: pip-audit; pre-commit; pytest; pytest-cov; Ruff | 2.10.1; 4.6.2; 9.1.1; 7.1.0; 0.13.3 | Apache-2.0; MIT; MIT; MIT; MIT | Permissive, development | Preserve applicable notices |
| go-judge; Caddy; Prometheus | 1.13.3; pinned image digest; 3.3.1 | MIT; Apache-2.0; Apache-2.0 | Permissive services | Keep upstream notices; no source changes made |
| MySQL Community; Grafana | 8.0; 11.6.0 | GPL-2.0-only; AGPL-3.0-only | Copyleft services | Run as separate unmodified services; retain notices and upstream source availability; review obligations before redistributing or modifying images |
| Python; Node.js image runtimes | 3.14; pinned image digest | PSF-2.0; MIT | Permissive runtimes | Preserve upstream license notices in redistributed images |
| APPS; APPS+ problem catalogs | Imported 500-problem selection, October 2026 | MIT; MIT | Permissive dataset | Credit source repositories and keep their notices; review per-problem provenance |
| TechniView logo | 2026 | MIT | Team-created | Credit team; included under project MIT license |
| D0-D2 design diagrams (docs/design/images/) | 2026 | MIT | Project documentation assets | Credit TechniView team; keep project notice |

MySQL and Grafana are copyleft. The team uses their unmodified service images across process boundaries, keeps TechniView application code under MIT, and will retain their notices and upstream source links with any image redistribution. Changes to either service or its distribution require a separate license review. The imported catalog contains source attribution per problem; a source link inside a prompt does not itself grant rights to an externally hosted image.

# Attribution list

The matching README attribution section gives source URLs and individual direct-dependency versions. The APPS and APPS+ repositories supplied publicly collected coding problems, adapted into the 500-problem catalog with duplicate statements removed and tests reviewed. Their repositories identify the datasets as MIT. The raw curation scripts remain outside this repository; the tracked catalog retains per-problem source metadata. The team reports no other tutorial or repository code snippets adapted into the application. The TechniView team created the MIT-licensed logo and maintains the six design-diagram PNG/SVG assets in docs/design/images/. No generated concept art is shipped in the app. The browser uses system fonts; no separately licensed font or icon pack is bundled.

# AI-use disclosure

"Generative AI tools may be used for drafting and code assistance but not for the design decisions or written analysis that are assessed in this course."

These uses fall in the class's **Generally OK** column. None was used as a substitute for the team's assessed architecture, data model, priorities, or written analysis. Each member inspected AI-assisted work in Git diffs and PRs; other members reviewed it through GitHub or manual diff review. Concept art was visually reviewed and was not shipped in the app.

| Tool | Used by | Task | Column | How verified |
|---|---|---|---|---|
| Gemini | Ryan Sippy | UI/dashboard mockups; UI boilerplate scaffolding; debugging | Generally OK | Diff and PR review; peer review |
| Gemini | Ryan Sippy | Issue/PR drafting; concept art | Generally OK | PR text reviewed; concept art visually inspected |
| Claude | Jason Bellerjeau | Temporary analytics scripts and database setup; debugging | Generally OK | Diff and PR review; peer review |
| Claude | Jason Bellerjeau | Issue/PR drafting; concept art | Generally OK | PR text reviewed; concept art visually inspected |
| Codex | Derek Corniello | Temporary test scripts, test boilerplate; debugging | Generally OK | Diff and PR review; peer review |
| Codex | Derek Corniello | Issue/PR drafting; concept art | Generally OK | PR text reviewed; concept art visually inspected |

The team confirms that its architecture, data model, priorities, and design rationale are its own. The members authorized their names as digital confirmation lines:

- **Ryan Sippy (digitally confirmed)**
- **Jason Bellerjeau (digitally confirmed)**
- **Derek Corniello (digitally confirmed)**